YAZILIM TEKNİK ŞARTNAMESİ (SRS)

Otonom Araç Uzaktan İzleme ve Destek Sistemi

Alan	Değer
Proje Adı	Otonom Araç Uzaktan İzleme ve Destek (Remote Monitoring & Assistance) Sistemi
Versiyon	13.0 (Siber Güvenlik Revizyonu - Nihai)
Önceki Versiyon	12.0
Tarih	04.03.2026
Kapsam	Araç Üstü Gateway Entegrasyonu, Bulut Sunucu (Backend), Web Dashboard (Frontend), Siber Güvenlik Gereksinimleri
Hazırlayan	
Onaylayan	

1. GİRİŞ VE AMAÇ

Bu doküman, Otokar Otomotiv ve Savunma Sanayi A.Ş. bünyesinde geliştirilen otonom araçların, web tabanlı bir ara yüz üzerinden uzaktan izlenmesi (Remote Monitoring), durum takibi yapılması ve tanımlı komutların (Minimum risk manevrası - MRM, Sistem Yeniden Başlatma, Klima, Kapı aç/kapa, dörtlü sinyalleri vb.) gönderilmesini (Remote Assistance) ve araç içerisindekiler ile anlık sesli iletişim sağlayacak yazılım sisteminin teknik, fonksiyonel ve siber güvenlik gereksinimlerini tanımlar.

Sistem; araç içine konumlandırılacak Secure Gateway donanımı, Bulut Sunucu ve Web Kullanıcı Ara Yüzü olmak üzere üç ana bileşenden oluşacaktır. Her bileşen, ISO/SAE 21434 ve UNECE WP.29 R155/R156 regülasyonlarına uygun siber güvenlik gereksinimlerini karşılayacak şekilde tasarlanacaktır.

1.1. TANIMLAR

Terim / Kısaltma	Tanım
HPCU	High Performance Computing Unit (Yüksek Performanslı Hesaplama Birimi).
RT-ECU	Real-time Electronic Control Unit (Gerçek Zamanlı Elektronik Kontrol Birimi).
Gateway	Otonom Sistem'in internete bağlantısını ve Uzak Sunucu ile iletişimi sağlayan birimdir.
Platform Bileşenleri	Otokar e-Centro platformunda halihazırda bulunan tüm bileşenleri (batarya, direksiyon, fren sistemi, CAN Hattı vb.) kapsar.
Otonom Donanımı	Otonom sürüşün gerçekleştirilmesi için gerekli donanımları (Algılama Sensörleri, HPCU, RT-ECU, Gateway) kapsar.
Otonom Yazılımı	Otonom Donanımı'nın üzerinde koşan, otonom sürüşün gerçekleştirilmesini sağlayan tüm yazılımları kapsar.
Otonom Araç	Otokar Otonom e-Centro'nun bünyesinde barındırdığı Platform Bileşenleri, Otonom Yazılımı ve Otonom Donanımı'nın bütününü kapsar.
Araç Üstü Haberleşme Yazılımı	Gateway üzerinde koşan, Uzak Sunucu ve Otonom Sistem verileri arasındaki iletişimi sağlayan yazılımların bütününü kapsar.
Uzak İstemci	Otonom Sistem'i Uzaktan İzleme ve Destek Sistemi vasıtasıyla gözlemleyebilen ve/veya yönetebilen yetkilendirilmiş cihazları kapsar.
Gözlem/Destek Ara Yüzü	Uzak İstemci'lerin izleme ve destek aksiyonlarını gerçekleştirebildikleri ağ tabanlı paneldir.
Uzak Sunucu	Uzaktan İzleme ve Destek Sistemi'nin Gateway üzerinden araç ile haberleştiği ve Gözlem/Destek Ara Yüzü bilgilerinin güncellendiği bulut tabanlı sunucudur.
CSMS	Cybersecurity Management System - ISO/SAE 21434 kapsamında organizasyonel siber güvenlik yönetim sistemi.
TARA	Threat Analysis and Risk Assessment - Tehdit analizi ve risk değerlendirmesi.
HSM	Hardware Security Module - Kriptografik anahtarların güvenli depolanması ve işlenmesi için donanım modülü.
mTLS	Mutual Transport Layer Security - Hem istemci hem sunucunun birbirine sertifika ile kimlik doğrulaması yapması.
SIEM	Security Information and Event Management - Güvenlik olaylarının merkezi izleme ve korelasyon sistemi.
SOC	Security Operations Center - Güvenlik operasyonlarının 7/24 izlendiği merkez.
SAST	Static Application Security Testing - Kaynak kod üzerinde yapılan statik güvenlik analizi.

DAST	Dynamic Application Security Testing - Çalışan uygulama üzerinde yapılan dinamik güvenlik testi.
SCA	Software Composition Analysis - Üçüncü parti bileşen ve kütüphanelerin zafiyet analizi.
SBOM	Software Bill of Materials - Yazılımda kullanılan tüm bileşen ve bağımlılıkların listesi.
CVE	Common Vulnerabilities and Exposures - Bilinen zafiyetlerin standart tanımlayıcısı.
CVSS	Common Vulnerability Scoring System - Zafiyet şiddeti puanlama sistemi (0.0-10.0).
OTA	Over-The-Air - Kablosuz ağ üzerinden uzaktan yazılım güncelleme.
IDS/IPS	Intrusion Detection/Prevention System - Saldırı tespit ve önleme sistemi.
WAF	Web Application Firewall - Web uygulaması güvenlik duvarı.
Zero Trust	Ağ içi veya dışı fark etmeksizin her erişim talebinin doğrulanması prensibi.
Fail-Safe	Sistem arızası durumunda güvenli duruma geçiş mekanizması.
Defense in Depth	Katmanlı güvenlik yaklaşımı - tek bir güvenlik katmanına güvenmeme prensibi.
Least Privilege	Kullanıcı ve sistemlerin yalnızca gerekli minimum yetkilerle çalışması prensibi.
KVKK	Kişisel Verilerin Korunması Kanunu (6698 sayılı).
NAC	Network Access Control - Ağa bağlanan cihazların kimlik doğrulaması ve yetkilendirilmesi.
IP Whitelist	Sadece önceden tanımlanmış IP adreslerinden erişime izin veren güvenlik mekanizması.

2. SİSTEM MİMARİSİ VE DONANIM ENTEGRASYONU

Yüklenici firma, yazılımı aşağıdaki donanım mimarisine uygun geliştirecektir:

2.1. Gateway Donanımı

Araç içerisinde 4G/5G bağlantısına sahip bir Gateway (Router/Edge PC) bulunacaktır. (iWave veya muadili)

- Gateway donanımı Secure Boot desteğine sahip olmalıdır.
- Kriptografik anahtar depolama için donanım tabanlı güvenlik modülü (HSM veya TPM) kullanılmalıdır.
- Gateway firmware'i dijital imza ile doğrulanabilir olmalıdır.
- Fiziksel müdahaleye (tamper) karşı tespit mekanizması bulunmalıdır.
- Debug portları (JTAG, UART) üretim cihazlarında devre dışı bırakılmalıdır.

2.2. Otonom PC Entegrasyonu

Gateway, Otonom Sürüş Bilgisayarı ile Ethernet üzerinden fiziksel bağlantı kuracaktır. Gateway, buluttan gelen veriyi ham (raw) veya tanımlı bir protokol ile Otonom PC'ye iletecek; Otonom PC tarafındaki ayrıştırma (parsing) işlemi Otokar tarafından yapılacaktır.

- Gateway ile Otonom PC arasındaki Ethernet bağlantısı, araç içi diğer ağlardan fiziksel veya VLAN bazlı izole edilmelidir.
- Gateway üzerinden Otonom PC'ye iletilen komutlar, dijital imza ile doğrulanmalıdır.

2.3. Ses Donanımı

Araç içi iletişim için kullanılacak Mikrofon ve Hoparlör kiti ile Çağrı Başlatma Butonu, Otonom PC'ye değil, doğrudan Gateway cihazına bağlanacaktır.

2.4. Bulut / Server Entegrasyonu

Sistem, ölçeklenebilir bulut altyapısı üzerinde çalışacaktır.

Sunucu altyapısı yüksek erişilebilirlik (High Availability) prensiplerine uygun tasarlanacaktır.

- Bulut ortamı, Defense in Depth (katmanlı güvenlik) prensibiyle tasarlanmalıdır.
- Sunucu ortamları (geliştirme, test, üretim) birbirinden ağ seviyesinde izole edilmelidir.
- Tüm sunucu erişimleri, merkezi kimlik yönetimi (IAM) ile kontrol edilmelidir.
- Sunucu işletim sistemleri ve bileşenleri, güvenlik yamalarıyla düzenli olarak güncellenmelidir (patch management).
- Sunucu ortamında kullanılmayan servisler ve portlar kapatılmalıdır (hardening).
- Container kullanılıyorsa, image'lar güvenlik taramasından geçirilmeli ve imzalanmalıdır.
- Veritabanı sunucuları, doğrudan internet erişimine kapalı olmalıdır (private subnet).
- Yedekleme verileri şifrelenmiş olarak saklanmalı ve düzenli olarak geri yükleme testi yapılmalıdır.

- Not: Bulut sunucu gereksinimler firma ile görüşülecek ve anlaşmaya varılan isterler doğrultusunda OTOKAR A.Ş. tarafından sağlanacaktır.

3. WEB DASHBOARD VE KULLANICI ARA YÜZÜ (UI/UX)

Geliştirilecek web ara yüzü, EK-2'de sunulan tasarım slaytlarına sadık kalınarak kodlanacaktır. Sistem aşağıdaki sayfa hiyerarşisine sahip olmalıdır:

3.1. Giriş Sayfası (Login Page)

3.1.1. Kullanıcılar, sistem yöneticisi tarafından verilen kullanıcı adı ve şifre ile güvenli giriş yapabilmelidir.

3.1.2. Güvenlik için "Beni Hatırla", "Şifremi Unuttum" ve İki Faktörlü Doğrulama (2FA) desteği bulunmalıdır.

3.1.3. Şifre politikası aşağıdaki minimum gereksinimleri karşılamalıdır:

- Minimum 12 karakter uzunluk
- Büyük harf, küçük harf, rakam ve özel karakter zorunluluğu
- Son 12 şifrenin tekrar kullanılamaması
- Maksimum 90 günlük şifre geçerlilik süresi
- Yaygın/sızdırılmış şifre listelerine (breached password database) karşı kontrol

3.1.4. Hesap kilitleme politikası:

- 5 başarısız giriş denemesinden sonra hesap 15 dakika geçici olarak kilitlenmelidir.
- Kilitlenme durumu sistem yöneticisine bildirilmelidir.
- Brute-force koruması için progressive delay (artan bekleme süresi) uygulanmalıdır.

3.1.5. Oturum yönetimi:

- Oturum token'ları kriptografik olarak güvenli rastgele değerler ile üretilmelidir.
- Oturum zaman aşımı: aktif oturum maksimum 8 saat, pasif oturum 30 dakika.
- Eşzamanlı oturum sayısı kullanıcı başına sınırlandırılmalıdır (maksimum 2).
- Çıkış yapıldığında oturum token'ı sunucu tarafında geçersiz kılınmalıdır (server-side invalidation).
- Oturum token'ları Secure, HttpOnly ve SameSite=Strict flag'leri ile cookie'de saklanmalıdır.

3.1.6. 2FA zorunluluğu: Admin ve Gözetmen rollerindeki kullanıcılar için 2FA zorunlu olmalıdır. TOTP (Time-based One-Time Password) veya FIDO2/WebAuthn desteklenmelidir.

3.2. Filo ve Araçlar Sayfası (Vehicles Page - Main Dashboard)

3.2.1. Harita Görünümü:

- Tüm kayıtlı araçların anlık konumları Google Maps ve/veya OpenStreet tabanlı bir harita üzerinde ikonlarla ve ikonların altında sisteme kayıtlı isimleri ile gösterilmelidir.
- Harita etkileşimli olmalı yakınlaştırma, uzaklaştırma ve kaydırma özelliklerine sahip olmalıdır.
- Durum özeti veya arama ile seçilen araç görsel olarak harita üzerinde vurgulanmalı ve ortalanmalı.
- Genel harita bakışına geri dönmek için bir “default” butonu olmalıdır.

3.2.2. Durum Özetleri (Quick View):

- Haritanın yanındaki/altındaki panelde araçların özet durumları (Plaka/ID, Batarya %, menzil, konum, Hız, Otonom Modu, Bağlantı Durumu) liste veya kart yapısında görselleştirilmelidir.
- Durum özeti üzerinden ilgili aracın detay ve izleme sayfasına geçme özelliği bulunmalıdır.
- Araç ikonları ve durum özetlerindeki liste veya kart yapıları aracın durumuna göre renk değiştirmelidir.(Örn: Yeşil = Sorunsuz, Kırmızı = Kritik Hata, Turuncu = Uyarı, Gri = Çevrimdışı)

3.2.3. Filtreleme ve Arama:

- Kullanıcılar araçları; "Aktif/Pasif", "Arızalı", "Düşük Batarya" gibi kriterleri filtreleyebilmeli ve Araç ID'sine göre arama yapabilmelidir.
- Giriş yapan kullanıcıya ve yetkisine göre sadece ilgili araçlar gösterilmelidir.

3.2.4. Üst Bigli Paneli:

- Sayfanın üst kısmında; toplam araç sayısı, aktif/çalışan araç sayısı, tamamlanan tur sayısı, toplam durak sayısı gibi verileri içeren özet istatistik paneli bulunmalıdır.

3.3. Araç Detay Dashboard Sayfası (Vehicle Specific Dashboard)

Bu sayfa, operatörün seçilen aracı izlediği "Kokpit" ekranıdır.

3.3.1. Canlı Video: Araçtaki minimum 5 kameradan gelen görüntü 1920x1080, 20 FPS, düşük gecikme (Low Latency) ile bu ekranda eş zamanlı izlenebilmelidir. Kameraların çerçevesi sağlıklı iken ve kamera ile bağlantı koptuğunda farklı renk olacak şekilde güncellenmelidir.

3.3.2. Kritik Veriler: Otonom sistem durumu, direksiyon açısı, anlık hız, menzil, sıcaklık, fren basınçları, ABS ve batarya durumu (%, sıcaklık, voltaj, amper) büyük ve okunaklı ikon ve göstergelerle sunulmalıdır. İkon ve göstergelerin üzerine mouse ile gelindiğinde kısa açıklamaları belirmelidir.

3.3.3. Basit Komutlar: Operatör, bu ekran üzerinden EK-1'deki tüm operasyonel komutları (Klima, Dörtlüler, Kapı vb.) hızlıca gönderebilmelidir. Komutlar tasarım dökümanında olduğu gibi altınında isimleri olan ikonlar şeklinde yapılmalıdır. Komutlar "Kritik" ve "Operasyonel" olarak ikiye ayrılmalıdır. İkonlarda push, toggle gibi özelliklere sahip olup anlaşılabilir olması için bir animasyon veya renk değişimi aksiyonları bulunmalıdır.

- Kritik Komutlar: Acil stop, kontrolü devralma gibi komutlar sayfa üzerinde sabit olmalıdır.
- Operasyonel Komutlar: Klima, iç ışık, silecek gibi ikincil komutlar ayrı bir "Konfor/Yardımcı Panel" altında gruplanmalıdır.

3.3.4. Arama Butonu: Operatör, bu ekran üzerinden bir buton ile araçla sesli iletişimi başlatabilmektedir.

3.3.5. Bağlantı Sağlığı ve Gecikme Takibi (Network Diagnostics): Operatörün müdahale güvenliğini ölçebilmesi için; anlık gecikme süresi (Latency - ms cinsinden), paket kaybı (Packet Loss) ve sinyal gücü (LTE/5G/Wi-Fi) ekranda sürekli güncel olarak gösterilmelidir. Gecikme süresi kritik eşiği (örn: 200ms) geçtiğinde görsel uyarı verilmelidir.

3.3.6. Operasyonel Mini Harita (Mini-Map): Dashboard ekranının bir köşesinde aracın hareketini gözlemleyeceğimiz bir mini harita yer almalıdır.

3.3.7. Uzak Sürücü İstek Butonu: Uzak sürücünün araca bağlanması için istek gönderecek bir buton eklenmelidir.

3.3.8. Data Kayıt Butonu: Basıldığında araç üzerinde veri kaydetmesi için gerekli komutu gönderecek bir buton eklenmelidir.

3.4. Araç Teknik İzleme ve Rota Yönetimi Sayfaları

3.4.1. Rota Yönetimi Sayfası:

- Sistem, harita üzerinden yeni rota oluşturmayı desteklemelidir; kullanıcı rota çizimi sırasında başlangıç noktası, aracığın duracağı durak noktalarını, geçmesi istenen yol için ara noktalar ve bitiş noktasını belirleyebilmelidir. Belirlenen noktalar sayfa üzerinden , İsim, id ve latitude-longitude özelliklerini ile kaydedilebilmelidir.
- Sistem, daha önce oluşturulmuş kayıtlı rotaları listeleyip seçmeyi sağlamalıdır.
- Sistem, rota üzerine durak eklemeyi ve durakları yönetmeyi desteklemelidir; her durak için durakta durup durulmaycağı, kapı aksiyonu,kapı açık kalma süresi gibi durak davranış parametreleri ayarlanabilmelidir.
- Sistem, tur bazlı durak iptaline izin vermelidir; kullanıcı seçilen rota üzerindeki durakları seçerek iptal edebiliyor olmalıdır.

- Kullanıcı, harita ekranında rota seçtikten sonra “Rota Gönder” komutunu verebilmelidir.

3.4.2. CANBUS Görselleştirme Sayfası:

- Araçtan gelen bütün CANBUS mesajları için açıklama ve ikon içeren bölümler yapılmalı ve verinin gelip gelmediği ve güncel değeri gösterilmelidir.
- Üzerine tıklandığı zaman ilgili CANBUS mesajı detayına girilmeli, zaman serisi grafikleri ve akan liste olarak gösterilmelidir.
- Sayfa üzerinde araç ve aranan mesajları filtrelemek için bir search bar bulunmalıdır.
- Sayfa üzerinde aracın bağlantı durumu, son gelen data tarihi ve şasi numarası gibi bilgiler görünür bir şekilde bulunmalıdır.

3.5. Raporlama Sayfası (Reports Page)

3.5.1. Raporlama Sayfası:

- Raporlar sayfa üzerinden araç, tarih aralığı, raporlanacak özellik ve zaman aralığı şeklinde filtreleme yapılabilmelidir.
- Değerler zaman serisi grafikleri, bar grafikleri gibi açıklayıcı grafik görselleri üzerinde gösterilmelidir.

3.5.2. Rapor Türleri:

- Alarm Raporları: Hangi araç, ne zaman, hangi hata kodunu (DTC) verdi?
- Güç Tüketimi: Batarya kullanım istatistikleri.
- CANBUS Logları: Belirli bir tarih aralığındaki teknik veri dökümü.
- Güvenlik Olay Raporları: Başarısız giriş denemeleri, yetkisiz erişim girişimleri, şüpheli aktiviteler.
- Erişim Denetim Raporları: Kim, ne zaman, hangi araca, hangi komutu gönderdi?
- Zafiyet Durum Raporu: Açık zafiyetler, SLA durumları, düzeltme geçmişi.

3.5.3. Dışa Aktarım: Raporlar PDF ve Excel formatında indirilebilir olmalıdır.

3.6. Yönetim Paneli (Admin/Settings Page)

3.6.1. Kullanıcı Yönetimi: Yeni kullanıcı oluşturma, şifre sıfırlama ve Rol Atama işlemleri yapılabilmelidir. Kullanıcılara ait telefon numarası, mail adresi ve şirket ismi gibi bilgiler tanımlanabilmelidir.

3.6.2. Araç Yönetimi: Sisteme yeni araç (Gateway ID) ekleme, araç profili düzenleme işlemleri buradan yönetilmelidir.

3.6.3. : Yetki Paneli: Yetki matrisinde belirtilen rollere ek olarak yeni roller tanımlanabilmelidir. Ek olarak hali hazırda olan ve yeni tanımlanan rollere yetki matrisindeki işlemlerden hangisini gerçekleştirip hangisini gerçekleştiremeyeceği yetkileri verilebilmelidir.

3.6.4. Yetki Matrisi: Hangi rolün hangi sayfayı görebileceği veya hangi komutu gönderebileceği buradan ayarlanabilmelidir.

Yetki / İşlem	Admin	Gözetmen	Operatör	İzleyici
Kullanıcı oluşturma/silme	Evet	Hayır	Hayır	Hayır
Rol atama/değiştirme	Evet	Hayır	Hayır	Hayır
Araç ekleme/çıkarma	Evet	Hayır	Hayır	Hayır
Yetki matrisi düzenleme	Evet	Hayır	Hayır	Hayır
Güvenlik loglarını görüntüleme	Evet	Evet	Hayır	Hayır
Güvenlik ayarları değiştirme	Evet	Hayır	Hayır	Hayır
Filo harita görünümü	Evet	Evet	Evet	Evet
Araç dashboard (canlı veri)	Evet	Evet	Evet	Evet
Canlı video izleme	Evet	Evet	Evet	Hayır
Kritik komut gönderme(MRM)	Evet	Evet	Evet	Hayır
Operasyonel komut gönderme (Klima, Kapı vb.)	Evet	Evet	Evet	Hayır
Rota oluşturma/gönderme	Evet	Evet	Evet	Hayır
VoIP sesli iletişim	Evet	Evet	Evet	Hayır
Rapor görüntüleme	Evet	Evet	Evet	Evet
Rapor dışa aktarma	Evet	Evet	Evet	Hayır
CANBUS log görüntüleme	Evet	Evet	Evet	Hayır
Sertifika/anahtar yönetimi	Evet	Hayır	Hayır	Hayır
OTA güncelleme başlatma	Evet	Hayır	Hayır	Hayır

3.6.5. Denetim İzleri (Audit Trail):

- Tüm kullanıcı işlemleri (giriş, çıkış, komut gönderme, ayar değişikliği) zaman damgası, kullanıcı kimliği ve IP adresi ile loglanmalıdır.
- Denetim logları değiştirilemez (immutable/append-only) formatta tutulmalıdır.
- Loglar minimum 5 yıl saklanmalıdır.
- Kritik işlemlerde (kullanıcı silme, rol değiştirme, araç çıkarma) ek onay mekanizması (4 göz prensibi) uygulanmalıdır.

3.6.6. Sertifika Yönetimi Paneli:

- Araç sertifikalarının durumu (geçerlilik, son kullanma tarihi) görüntülenebilmelidir.
- Sertifika yenileme ve iptal (revocation) işlemleri bu panelden yönetilebilmelidir.
- Süresi dolmak üzere olan sertifikalar için otomatik uyarı mekanizması.

4. OLAY YÖNETİMİ VE BİLDİRİMLER (POP-UPS)

4.1. Global Uyarı Sistemi: Yetkili kullanıcılar hangi sayfada olursa olsun; bir araçtan "Kritik Arıza" veya "Yolcu Arama İsteği" geldiğinde ekranda bir Pop-up açılmalıdır.

4.2. Aksiyon Alma: Pop-up üzerinde hatanın kaynağı yazmalı ve "Araca Git" butonu ile doğrudan ilgili aracın Dashboard Sayfasına yönlendirme yapılmalıdır.

4.3. Sesli Uyarı: Pop-up açıldığında tarayıcı üzerinden sesli ikaz verilmelidir.

4.4. Güvenlik Olay Bildirimleri:

- Aşağıdaki güvenlik olayları, operasyonel uyarılarla aynı mekanizma ile bildirilmelidir:
  - Gateway ile sunucu arasında beklenmeyen bağlantı kopması veya kimlik doğrulama hatası
  - Araç sertifikası doğrulama hatası (olası sahte cihaz)
  - Tekrarlayan başarısız API kimlik doğrulama denemeleri
  - Anormal veri trafiği paterni (olası veri sızıntısı veya MITM)
  - Gateway firmware bütünlüğü doğrulama hatası
  - Bilinmeyen IP'den erişim girişimi

4.5. Güvenlik olaylarında pop-up kırmızı renk kodlu olmalı ve olay detayı (kaynak IP, zaman, etkilenen araç/kullanıcı) gösterilmelidir.

4.6. Güvenlik olayları ayrı bir log kuyruğunda tutulmalı ve güvenlik raporlarına dahil edilmelidir.

5. UZAKTAN KOMUT VE HABERLEŞME GEREKSİNİMLERİ

5.1. Komut Altyapısı: Operatör, ara yüz üzerinden EK-1'deki tabloda belirtilen spesifik komutları gönderebilmelidir. Her komut, araç tarafından "Alındı (ACK)" ve "Uygulandı (Executed)" şeklinde teyit edilmelidir.

5.2. Güvenlik Onayı: MRM gibi kritik komutlar için operatöre "Onaylıyor musunuz?" penceresi açılmalıdır.

5.2.1. Komut Güvenliği:

- Her komut, gönderen operatörün kimlik ve yetki bilgisi ile birlikte iletilmelidir.
- Kritik komutlar (MRM, sistem yeniden başlatma) için çift onay mekanizması: UI onay penceresi + 2FA doğrulaması.
- Tüm gönderilen komutlar dijital imza (HMAC-SHA256 veya Ed25519) ile bütünlüğü doğrulanmalıdır.
- Komut tekrar saldırılarına (replay attack) karşı nonce ve zaman damgası doğrulaması yapılmalıdır.
- Zaman damgası toleransı maksimum 30 saniye olmalıdır (stale komutlar reddedilmelidir).
- Araç tarafında bilinmeyen veya yetkisiz komutlar loglanmalı ve reddedilmelidir.
- Belirli bir sürede (ör. 5 dakika) aşırı sayıda komut gönderilirse rate limiting uygulanmalıdır.

5.3. Canlı Video Akışı (Video Streaming):

- 1920x1080, 20 FPS, düşük gecikme.
- Bant genişliği yönetimi için video akışı varsayılan olarak kapalı gelmeli, on-demand başlatılmalıdır.
- Adaptive Bitrate özelliğine sahip olmalıdır.
- Video akışı uçtan uca şifrelenmelidir (DTLS/SRTP).
- Video akışına erişim, oturum bazlı yetkilendirme ile kontrol edilmelidir.
- Video kaydı yapılması durumunda kayıtlar şifrelenmiş olarak saklanmalıdır.

5.4. Çift Yönlü Sesli İletişim (VoIP):

- Internet üzerinden (VoIP) çift yönlü sesli görüşme sağlanmalıdır.
- Yankı önleme (Echo Cancellation) özelliği aktif olmalıdır.
- VoIP trafiği SRTP (Secure Real-time Transport Protocol) ile şifrelenmelidir.
- Oturum başlatma SIP/TLS veya eşdeğer güvenli sinyal protokolü kullanmalıdır.

6. SİBER GÜVENLİK GEREKSİNİMLERİ

6.1. Ağ ve Bağlantı Mimarisi

6.1.1. Protokol Seçimi

- Telemetri Verileri (Upstream): MQTT over TLS 1.3 veya AMQP. Araçtan sunucuya akan anlık veriler için.
- Komut Yönetimi (Downstream): WebSocket (WSS) veya MQTT over TLS. Sunucudan araca giden komutlar için.
- Video Akışı: Secure WebRTC (DTLS + SRTP) veya SRT (Secure Reliable Transport).
- Tüm protokollerde TLS 1.3 zorunlu olmalıdır. TLS 1.2 ve altı kabul edilmemelidir.
- Zayıf cipher suite'ler (RC4, DES, 3DES, NULL) devre dışı bırakılmalıdır.
- Forward Secrecy (ECDHE) destekleyen cipher suite'ler tercih edilmelidir.
- Certificate pinning, Gateway firmware'inde uygulanmalıdır.

6.1.2. VPN Zorunluluğu

Araç üzerindeki Gateway ile Bulut Sunucu arasındaki tüm trafik, operatörden bağımsız bir Site-to-Site VPN veya Private APN tüneli üzerinden geçirilerek halka açık internetten izole edilmelidir.

- VPN protokolü: IPSec (IKEv2) veya WireGuard kullanılmalıdır. PPTP ve L2TP kabul edilmemelidir.
- VPN tüneli kopması durumunda trafiğin açık ağa çıkması engellenmelidir (kill switch).
- VPN kimlik doğrulaması sertifika tabanlı olmalıdır (pre-shared key değil).

6.1.3. Bağlantı Yönetimi (Connection Lifecycle)

- Gateway, sunucu ile bağlantısı koptuğunda (Heartbeat loss), otomatik olarak yeniden bağlanmayı denemelidir.
- Bağlantı kopukluğu belirli bir saniyeyi geçerse, Gateway otonom bilgisayara "Bağlantı Koptu" sinyali göndermeli ve araç Fail-Safe moduna geçebilmelidir.
- Heartbeat mesajları kimlik doğrulamalı olmalıdır (sahte heartbeat enjeksiyonuna karşı).
- Yeniden bağlantı denemelerinde exponential backoff uygulanmalıdır (DoS önleme).
- Gateway, sunucu sertifikasını her yeniden bağlantıda doğrulamalıdır.

6.1.4. Ağ Segmentasyonu

- Araç içi ağ, fonksiyonel alanlarına göre segmente edilmelidir (telemetri, video, komut, CAN).
- Bulut tarafında DMZ, uygulama katmanı ve veritabanı katmanı ayrı ağ segmentlerinde olmalıdır.
- Segmentler arası trafiğe firewall kuralları uygulanmalıdır.
- Yönetim trafiği (SSH, RDP) ayrı bir yönetim ağı üzerinden sağlanmalıdır.

6.1.5. Cihaz Doğrulama ve Ağ Erişim Kontrolü (NAC)

Ağa bağlanan tüm cihazlar (Gateway'ler, operatör terminalleri, sunucular) kimlik doğrulamasından geçmelidir:

- Operatör terminalleri için donanım kimliği doğrulaması (UUID ve/veya MAC adresi) uygulanmalıdır. Sadece kayıtlı cihazlar ağa dahil olabilmelidir.
- MAC adresi doğrulaması tek başına yeterli değildir (MAC spoofing riski). mTLS sertifikası veya TPM-based attestation ile desteklenmelidir.
- Ağa bağlanan her cihaz için 802.1X (port-based network access control) veya eşdeğer bir NAC mekanizması uygulanmalıdır.
- Kayıtlı olmayan veya güvenlik politikasına uymayan cihazlar (güncel olmayan OS, devre dışı antivirüs vb.) karantina ağına yönlendirilmelidir.
- Cihaz envanteri güncel tutulmalı ve düzenli olarak denetlenmelidir.
- Kayıp veya çalıntı cihazların ağ erişimi uzaktan iptal edilebilmelidir.
- Yeni cihaz kaydı sadece Admin rolü tarafından yapılabilmelidir.

6.2. Veri Güvenliği ve Şifreleme

6.2.1. İletim Halindeki Veri (Data in Transit)

Tüm veri trafiği (API çağrıları, video akışı ve soket bağlantıları) TLS 1.3 protokolü ile şifrelenmelidir. Şifrelenmemiş (Plain text/HTTP) hiçbir veri paketi ağa çıkmamalıdır.

6.2.2. Durağan Veri (Data at Rest)

- Veritabanında saklanan tüm hassas veriler AES-256 ile şifrelenmelidir.
- Şifreleme anahtarları, ayrı bir anahtar yönetim sistemi (KMS) ile yönetilmelidir.
- Gateway üzerinde geçici olarak saklanan veriler (offline buffer) şifrelenmiş disk bölümünde tutulmalıdır.
- Yedekleme dosyaları şifrelenmiş olarak saklanmalıdır.
- Log dosyaları hassas veri içermemelidir (veri maskeleme uygulanmalıdır).

6.2.3. Karşılıklı Kimlik Doğrulama (mTLS)

Araç ve Sunucu birbirine bağlanırken sunucu sertifikası yanı sıra, aracın da yetkili bir araç olduğunu kanıtlayan Client Certificate (mTLS) yapısı kullanılmalıdır. Her aracın kendine ait, benzersiz bir dijital sertifikası olmalıdır.

- Her araç için üretim sırasında benzersiz bir X.509 sertifikası oluşturulmalıdır.
- Sertifikalar HSM veya TPM içinde saklanmalı, yazılım seviyesinde erişilememelidir.
- Sertifika geçerlilik süresi maksimum 2 yıl olmalı, otomatik yenileme desteklenmelidir.
- Sertifika iptal listesi (CRL) veya OCSP ile gerçek zamanlı iptal kontrolü yapılmalıdır.
- Özel bir PKI (Private Certificate Authority) kurulmalıdır. Public CA kullanılmamalıdır.

6.2.4. Veri Bütünlüğü

Gönderilen kritik komutlar (MRM vb.), yolda değiştirilmediğinden emin olmak için dijital imza ile doğrulanmalıdır.

- Komut imzalama: HMAC-SHA256 veya Ed25519 dijital imza.
- Telemetri verilerinde bütünlük kontrolü: Her mesajda SHA-256 hash.
- İmza doğrulaması başarısız olan mesajlar kesinlikle reddedilmeli ve loglanmalıdır.

6.2.5. Anahtar Yönetimi (Key Management)

- Kriptografik anahtarlar düzenli aralıklarla rotasyona tabi tutulmalıdır (maksimum 12 ay).
- Anahtar üretimi CSPRNG (Cryptographically Secure Pseudo-Random Number Generator) ile yapılmalıdır.
- Anahtarlar kaynak kodda veya konfigürasyon dosyalarında açık metin olarak bulunmamalıdır.
- Anahtar yedekleme ve kurtarma prosedürleri tanımlanmalıdır.
- Kompromize olmuş bir anahtar durumunda acil iptal ve yenileme prosedürü tanımlanmalıdır.

6.3. Erişim Güvenliği

6.3.1. API Güvenliği

Web Dashboard'tan sunucuya yapılan tüm istekler OAuth2 / JWT standardı ile yetkilendirilmelidir.

- Access token süresi maksimum 15 dakika, refresh token süresi maksimum 24 saat olmalıdır.
- JWT imzalama algoritması RS256 veya ES256 olmalıdır (HS256 kabul edilmemelidir).
- Tüm API endpoint'leri yetki kontrolünden geçmelidir (Broken Access Control önleme).
- API yanıtlarında hassas bilgi sızıntısı olmamalıdır (stack trace, iç IP adresleri, veritabanı hata mesajları).
- CORS politikası sadece izin verilen origin'lere açık olmalıdır. Wildcard (*) kullanılmamalıdır.
- API versiyonlama uygulanmalı, eski versiyonlar güvenlik güncellemesi almaya devam etmelidir.
- Input validation: Tüm API girdileri whitelist tabanlı doğrulamadan geçmelidir.
- Rate limiting: API endpoint'lerine kullanıcı ve IP bazında rate limiting uygulanmalıdır.

6.3.2. IP Whitelist Erişim Kontrolü

Sunucu ve uygulamaya ağ seviyesinde erişim, sadece önceden tanımlanmış IP adresleri üzerinden sağlanmalıdır:

- Dashboard ve yönetim API'lerine erişim, kurum tarafından belirlenen statik IP adresleri (Whitelist/Beyaz Liste) ile kısıtlanmalıdır.
- Whitelist dışından gelen tüm erişim talepleri firewall seviyesinde reddedilmelidir.
- IP whitelist yönetimi, sadece Admin rolündeki kullanıcılar tarafından yapılabilmelidir.

- VPN üzerinden bağlanan uzak operatörler için VPN çıkış IP'leri whitelist'e eklenmelidir.
- IP whitelist değişiklikleri loglanmalı ve değişiklik yapan kullanıcı kaydedilmelidir.
- Acil durumlarda geçici IP ekleme mekanizması bulunmalı, geçici IP'ler otomatik olarak 24 saat sonra sona ermelidir.

6.3.3. Web Uygulama Güvenliği

- OWASP Top 10 (2021) zafiyetlerine karşı koruma sağlanmalıdır:
  - A01 - Broken Access Control: Rol tabanlı erişim kontrolü, IDOR koruması
  - A02 - Cryptographic Failures: Zayıf şifreleme kullanılmaması
  - A03 - Injection: SQL injection, NoSQL injection, OS command injection, XSS koruması
  - A04 - Insecure Design: Threat modeling sonuçlarına göre güvenli tasarım
  - A05 - Security Misconfiguration: Varsayılan şifre/ayar kullanılmaması, gereksiz özellikler kapatılmalı
  - A06 - Vulnerable Components: Bilinen zafiyetli bileşen kullanılmaması (SCA)
  - A07 - Authentication Failures: Güçlü kimlik doğrulama mekanizmaları
  - A08 - Software and Data Integrity: CI/CD pipeline güvenliği, imzalı güncellemeler
  - A09 - Security Logging and Monitoring: Yeterli loglama ve izleme
  - A10 - SSRF: Server-Side Request Forgery koruması
- HTTP güvenlik header'ları zorunludur:
  - Content-Security-Policy (CSP): unsafe-inline ve unsafe-eval kullanılmamalı
  - X-Content-Type-Options: nosniff
  - X-Frame-Options: DENY
  - Strict-Transport-Security: max-age=31536000; includeSubDomains
  - Referrer-Policy: strict-origin-when-cross-origin
  - Permissions-Policy: kamera, mikrofon gibi API'ler sadece gerektiğinde izin verilmeli

6.3.4. DDoS ve Bot Koruması

Sunucu altyapısı aşırı istek yüklemesine karşı korumalı olmalıdır.

- Web Application Firewall (WAF) konumlandırılmalıdır.
- Uygulama katmanı (Layer 7) DDoS koruması aktif olmalıdır.
- IP bazlı rate limiting ve geo-blocking desteği bulunmalıdır.
- Bot tespit mekanizması (CAPTCHA, JavaScript challenge) uygulanmalıdır.

6.3.5. Penetrasyon Testi

Yüklenici firma, projeyi teslim etmeden önce bağımsız bir kuruluşa veya Otokar siber güvenlik ekibine Penetrasyon Testi yaptırmayı ve çıkan tüm açıkları kapatmayı taahhüt eder.

- Penetrasyon testi kapsamı:
  - Web Dashboard (frontend + backend API)
  - Gateway firmware ve embedded yazılım
  - Araç-Sunucu iletişim kanalı (MQTT/WebSocket)
  - Bulut altyapısı (AWS/Azure konfigürasyonu)
  - VPN/ağ tüneli güvenliği
  - Mobil uygulama (varsa)
- Test standartları: OWASP Testing Guide v4, PTES (Penetration Testing Execution Standard).
- Kritik ve Yüksek seviyeli bulgular kesin kabul (SAT) öncesinde kapatılmalıdır.
- Orta seviyeli bulgular için düzeltme planı ve takvim sunulmalıdır.
- Düzeltme sonrası doğrulama testi (re-test) yapılmalıdır.
- Her major release öncesinde penetrasyon testi tekrarlanmalıdır.
- Test sonuçları gizli tutulmalı ve sadece yetkili kişilerle paylaşılmalıdır.

6.4. Güvenli Yazılım Geliştirme Yaşam Döngüsü (Secure SDLC)

Yüklenici firma, yazılım geliştirme sürecinde aşağıdaki güvenlik aktivitelerini uygulamalıdır:

6.4.1. Tasarım Aşaması

- Threat Modeling: Her major özellik için tehdit modellemesi (STRIDE veya PASTA metodolojisi) yapılmalıdır.
- Güvenlik gereksinimleri, fonksiyonel gereksinimlerle birlikte tanımlanmalı ve izlenebilir olmalıdır.
- Güvenli tasarım prensipleri (Least Privilege, Defense in Depth, Fail Secure, Separation of Duties) uygulanmalıdır.

6.4.2. Geliştirme Aşaması

- Güvenli kodlama standartları (OWASP Secure Coding Practices, CERT Coding Standards) takip edilmelidir.
- Kaynak koda erişim, rol bazlı olarak kısıtlanmalıdır (branch protection, code review zorunluluğu).
- Hassas veriler (API anahtarları, şifreler, sertifikalar) kaynak kodda bulunmamalıdır. Secrets management aracı kullanılmalıdır.
- Her commit'te otomatik SAST (Static Application Security Testing) taraması çalıştırılmalıdır.
- Her pull request en az bir güvenlik bilgisi olan geliştirici tarafından review edilmelidir.

6.4.3. Test Aşaması

- SAST: Kaynak kod statik güvenlik analizi (ör. SonarQube, Semgrep, Checkmarx).
- DAST: Çalışan uygulama üzerinde dinamik güvenlik testi (ör. OWASP ZAP, Burp Suite).
- SCA: Üçüncü parti bileşen zafiyet taraması (ör. Snyk, OWASP Dependency-Check).
- Container taraması: Docker image güvenlik taraması (ör. Trivy, Grype).
- Fuzz testing: Kritik API endpoint'leri ve parser'lar için fuzzing testi.

- Tüm güvenlik test sonuçları raporlanmalı ve izlenebilir olmalıdır.

6.4.4. Dağıtım (Deployment) Aşaması

- CI/CD pipeline'ında güvenlik kapıları (security gates) tanımlanmalıdır.
- Kritik veya yüksek seviyeli zafiyet bulunan build'ler otomatik olarak durdurulmalıdır.
- Deployment artifact'ları dijital imza ile doğrulanmalıdır.
- Üretim ortamına erişim en az iki kişinin onayını gerektirmelidir.

6.5. Zafiyet Yönetimi

Yazılım yaşam döngüsü boyunca keşfedilen zafiyetlerin yönetim süreci:

6.5.1. Zafiyet Sınıflandırma

Zafiyetler CVSS v3.1 puanlama sistemine göre sınıflandırılmalıdır:

Seviye	CVSS Puanı	Tanım	Örnek
Kritik	9.0 - 10.0	Uzaktan yetkisiz erişim, araç kontrolü ele geçirme, veri sızıntısı	RCE, Authentication Bypass, MRM komutu manipülasyonu
Yüksek	7.0 - 8.9	Önemli güvenlik kontrolü atlatma, hassas veri erişimi	SQL Injection, Privilege Escalation, mTLS bypass
Orta	4.0 - 6.9	Sınırlı etki, ek koşul gerektiren zafiyetler	XSS (Stored), CSRF, bilgi ifşası (information disclosure)
Düşük	0.1 - 3.9	Minimal etki, istismarı zor zafiyetler	Bilgilendirici header eksikliği, minor bilgi sızıntısı
Bilgi	0.0	Güvenlik iyileştirme önerileri, en iyi pratik tavsiyeleri	Versiyon bilgisi ifşası, gereksiz HTTP metod desteği

6.5.2. Zafiyet Düzeltme SLA

Keşfedilen zafiyetler aşağıdaki sürelerde düzeltilmelidir:

Seviye	İlk Müdahale	Geçici Çözüm (Workaround)	Kalıcı Düzeltme (Patch)	Doğrulama (Re-test)
Kritik	1 saat	4 saat	24 saat	Düzeltme sonrası 24 saat içinde
Yüksek	4 saat	1 iş günü	7 takvim günü	Düzeltme sonrası 48 saat içinde
Orta	1 iş günü	5 iş günü	30 takvim günü	Sonraki planlı test döngüsünde
Düşük	3 iş günü	-	90 takvim günü	Sonraki major release'de
Bilgi	5 iş günü	-	Sonraki major release	-

- Kritik zafiyetlerde 7/24 müdahale zorunludur (mesai dışı dahil).
- SLA süreleri iş günü değil, takvim günü olarak sayılır (Kritik ve Yüksek seviyeler için).
- Geçici çözüm uygulanması kalıcı düzeltme yükümlülüğünü ortadan kaldırmaz.
- SLA ihlali durumunda Otokar'ın yaptırım uygulama hakkı saklıdır (madde 9.4'e bakınız).

6.5.3. Zafiyet İzleme ve Raporlama

- Tüm zafiyetler bir zafiyet takip sistemi (bug tracker) üzerinde izlenmelidir.
- Her zafiyet için: keşif tarihi, CVSS puanı, etkilenen bileşen, sorumluluk, düzeltme durumu, test sonucu kaydedilmelidir.
- Aylık zafiyet durum raporu Otokar'a sunulmalıdır.
- Kritik ve yüksek seviyeli zafiyetler keşfedildiği anda Otokar'a bildirilmelidir.

6.5.4. Üçüncü Parti Zafiyet İzleme

- Kullanılan tüm açık kaynak ve ticari kütüphaneler için CVE izleme yapılmalıdır.
- Bilinen zafiyetli bileşen kullanılması durumunda, zafiyet düzeltme SLA'sı aynı şekilde uygulanır.
- SBOM (Software Bill of Materials), her release ile birlikte güncellenerek Otokar'a teslim edilmelidir.

6.6. Güvenlik İzleme ve Loglama

6.6.1. Güvenlik Logları

Aşağıdaki olaylar minimum olarak loglanmalıdır:

- Başarılı ve başarısız kimlik doğrulama denemeleri (kullanıcı, IP, zaman)
- Yetkilendirme hataları (erişim reddedilen kaynaklar)
- Kritik komut gönderme işlemleri (kim, hangi araca, ne zaman, hangi komut)
- Kullanıcı yönetimi işlemleri (oluşturma, silme, rol değişikliği)
- Araç sertifikası doğrulama olayları
- API rate limiting tetiklenmeleri
- Gateway bağlantı/kopma olayları
- OTA güncelleme işlemleri
- Konfigürasyon değişiklikleri
- Veritabanı yönetim işlemleri

6.6.2. Log Formatı ve Saklama

- Loglar yapılandırılmış formatta (JSON) üretilmelidir.
- Her log kaydında: zaman damgası (UTC, ISO 8601), olay tipi, kaynak IP, kullanıcı kimliği, sonuç (başarılı/başarısız), detay alanı bulunmalıdır.
- Loglar merkezi bir log sunucusuna (SIEM) gönderilmelidir.
- Güvenlik logları minimum 2 yıl, operasyonel loglar minimum 1 yıl saklanmalıdır.

- Log dosyalarına yazma erişimi sadece log servisine, okuma erişimi sadece yetkili personele verilmelidir.
- Logların bütünlüğü hash zincirleme veya imza ile korunmalıdır (tamper-proof).

6.6.3. Güvenlik İzleme (Monitoring)

- Anomali tespiti için korelasyon kuralları tanımlanmalıdır (ör. aynı IP'den 10 başarısız giriş = alarm).
- Aşağıdaki senaryolar için otomatik alarm kuralları tanımlanmalıdır:
  - Brute-force saldırı tespiti
  - Anormal saatlerde erişim (mesai dışı)
  - Olağandışı coğrafi konumdan erişim
  - Birden fazla araçtan eşzamanlı kritik hata
  - Gateway firmware değişikliği algılama
  - Anormal veri hacmi (data exfiltration şüphesi)

6.7. Siber Güvenlik Olay Müdahale Planı

Yüklenici, aşağıdaki olay müdahale sürecini tanımlayan dokümantasyon sağlamalıdır:

6.7.1. Olay Sınıflandırma

Seviye	Tanım	Örnek Senaryo	Eskalasyon
SEV-1 (Kritik)	Araç güvenliğini doğrudan tehdit eden, hemen müdahale gerektiren olay	Araç kontrolünün ele geçirilmesi, veri sızıntısı, MRM manipülasyonu	Anında CEO/CTO + Otokar CISO bilgilendirilir
SEV-2 (Yüksek)	Sistem bütünlüğünü tehdit eden, hızlı müdahale gerektiren olay	Sunucu sızıntısı, kimlik bilgisi çalınması, kötü amaçlı OTA	4 saat içinde üst yönetime bilgi
SEV-3 (Orta)	Sınırlı etkili, planlı müdahale gerektiren olay	Tek kullanıcı hesabı ele geçirilmesi, XSS zafiyeti istismarı	1 iş günü içinde ilgili yöneticilere bilgi
SEV-4 (Düşük)	Minimal etkili, izleme gerektiren olay	Port tarama tespiti, başarısız brute-force girişimi	Haftalık raporda bilgi

6.7.2. Müdahale Aşamaları

- 1. Tespit ve Tanımlama: Olayın kapsamı, etkilenen sistemler ve potansiyel etki belirlenir.
- 2. Sınırlandırma (Containment): Olayın yayılmasını önlemek için acil aksiyonlar alınır (etkilenen hesap kilitleme, ağ izolasyonu, sertifika iptali).
- 3. Eradikasyon: Tehdidin kök nedeni tespit edilir ve ortamdan temizlenir.
- 4. Kurtarma (Recovery): Etkilenen sistemler güvenli duruma getirilir ve normale döndürülür.
- 5. Olay Sonrası Analiz (Post-Incident Review): Olay raporu hazırlanır, kök neden analizi yapılır, önleyici tedbirler tanımlanır.

6.7.3. İletişim Planı

- Siber güvenlik olaylarında Otokar iletişim noktası: [CISO / Güvenlik Müdürü bilgileri]
- Yüklenici iletişim noktası: [7/24 ulaşılabilir güvenlik sorumlusu]
- SEV-1 ve SEV-2 olaylarında yazılı bildirim zorunludur (e-posta + telefon).
- Yasal bildirim gereksinimi olan olaylarda (veri ihlali) KVKK ve ilgili düzenleyici kurumlara bildirim sorumluluğu Otokar'dadır; yüklenici gerekli bilgi ve desteği sağlamakla yükümlüdür.

6.8. Tedarik Zinciri Güvenliği

- SBOM: Yazılımda kullanılan tüm bileşenlerin (açık kaynak, ticari, dahili) listesi SPDX veya CycloneDX formatında tutulmalıdır.
- Üçüncü parti bileşenler, bilinen zafiyet veritabanlarına (NVD, GitHub Advisory, OSV) karşı düzenli olarak taranmalıdır.
- Bağımlılık karması (dependency pinning): Tüm bağımlılıklar sabitlenmiş versiyonlarla ve hash doğrulaması ile kullanılmalıdır.
- Güvenilir kaynaklardan temin: Bileşenler yalnızca resmi ve güvenilir kaynaklardan (npm, PyPI, Maven Central vb.) indirilmelidir.
- Typosquatting ve dependency confusion saldırılarına karşı özel registry kullanımı değerlendirilmelidir.
- İkili (binary) bileşenlerin bütünlüğü imza doğrulaması ile kontrol edilmelidir.

6.9. Gateway ve Araç Üstü Güvenlik

6.9.1. Firmware Güvenliği

- Secure Boot: Gateway, yalnızca imzalı firmware ile başlatılmalıdır.
- Firmware imza doğrulaması: Boot sırasında firmware bütünlüğü ve imzası kontrol edilmelidir.
- Measured Boot: Boot sürecinin her aşaması ölçülmeli ve güvenilir platform modülüne (TPM) kaydedilmelidir.
- Debug modu: Üretim cihazlarında debug modu ve geliştirici araçları devre dışı bırakılmalıdır.

6.9.2. Çalışma Zamanı Güvenliği

- Gateway üzerinde sadece gerekli servisler çalışmalıdır (minimal attack surface).
- Dosya sistemi bütünlük kontrolü (integrity monitoring) periyodik olarak yapılmalıdır.
- Bellek koruma mekanizmaları (ASLR, DEP/NX, Stack Canaries) aktif olmalıdır.
- Olağandışı süreç aktivitesi veya ağ trafiği tespit edildiğinde alarm üretilmelidir.

6.9.3. Fiziksel Güvenlik

- Gateway kasası fiziksel müdahaleye karşı korumalı (tamper-evident) olmalıdır.
- Fiziksel müdahale tespitinde anahtar materyali silinmeli (zeroization) veya alarm üretilmelidir.
- Harici portlar (USB, SD kart) üretim cihazlarında devre dışı bırakılmalı veya fiziksel olarak kapatılmalıdır.

6.10. OTA (Over-The-Air) Güncelleme Güvenliği

- Güncelleme paketi, yüklenici firmanın özel anahtarı ile dijital olarak imzalanmalıdır.
- Gateway, güncelleme paketinin imzasını doğruladıktan sonra yüklemelidir. İmza doğrulaması başarısız olan paketler kesinlikle reddedilmelidir.
- Güncelleme sırasında güç kaybı veya bağlantı kopması durumunda güvenli geri dönüş (rollback) mekanizması olmalıdır (A/B partition).
- Güncelleme geçmişi loglanmalıdır (kim başlattı, ne zaman, hangi versiyon, sonuç).
- Güncelleme paketi şifrelenmiş olarak iletilmeli, transit sırasında manipüle edilememeli ve depolanırken şifreli tutulmalıdır.
- Downgrade koruması: Daha eski bir firmware versiyonuna geri dönüş, yönetici onayı olmadan engellenmelidir (anti-rollback counter).
- Güncelleme, araç hareket halindeyken başlatılmamalıdır (güvenlik kısıtı).
- Güncelleme sonrası otomatik self-test çalıştırılmalı, test başarısız olursa önceki versiyona otomatik geri dönülmelidir.
- UNECE R156 (Software Update Management System) gereksinimlerine uyum sağlanmalıdır.

6.11. Veri Sınıflandırma ve Koruma

Sınıf	Tanım	Örnekler	Koruma Gereksinimleri
Çok Gizli	İfşası araç güvenliğini veya insan hayatını tehlikeye atan veriler	Şifreleme anahtarları, araç kontrol komutları, firmware imza anahtarları	HSM'de saklama, en az iki kişi erişim, loglama, şifreleme zorunlu
Gizli	İfşası kurumsal zarara yol açabilecek veriler	Kullanıcı kimlik bilgileri, araç konum geçmişi, API anahtarları, sertifikalar	Şifrelenmiş saklama, rol bazlı erişim, loglama zorunlu
İç Kullanım	Kurum içi paylaşıma uygun veriler	Telemetri verileri, CANBUS logları, operasyonel raporlar	Erişim kontrolü, şifreli iletim
Genel	Kamuya açık veriler	Genel araç bilgileri, kamuya açık API dokümantasyonu	Bütünlük kontrolü yeterli

- Kişisel veriler (operatör kimlikleri, yolcu arama kayıtları) KVKK kapsamında işlenmelidir.
- Veri saklama süreleri veri sınıfına göre tanımlanmalıdır.
- Veri imha prosedürü tanımlanmalıdır (güvenli silme, kriptografik erasure).
- Geliştirme ve test ortamlarında gerçek veriler kullanılmamalıdır (veri maskeleme/anonimleştirme).

7. TEST, DOĞRULAMA VE KABUL KRİTERLERİ

7.1. Fabrika Kabul Testleri (FAT)

Yazılım sahaya inmeden önce, araç statik durumda iken tüm fonksiyonların çalıştığı doğrulanmalıdır.

- Tüm komutlar (EK-1 listesi) tek tek denenmeli ve başarılı sonuç verdiği raporlanmalıdır.

7.2. Saha Kabul Testleri (SAT)

- Sistem, gerçek bir araç üzerinde ve gerçek GSM şebekesi (4G/5G) altında test edilmelidir.
- Araç hareket halindeyken video akışının kopmadığı ve komut gecikmesinin belirlenen limitler içinde kaldığı ispatlanmalıdır.
- Acil durum senaryosu canlandırılmalı ve sistemin fail-safe davranışı test edilmelidir.

7.3. Kullanıcı Kabul Testi (UAT)

Otokar'ın sağlayacağı müşteri operatörün, eğitim almadan arayüzü kullanabildiği ve belirlenen senaryoları yardımsız gerçekleştirebildiği doğrulanmalıdır.

7.4. Güvenlik Kabul Testleri (SecAT)

Kesin kabul (SAT) öncesinde aşağıdaki güvenlik testleri başarıyla tamamlanmalıdır:

Test Türü	Kapsam	Kabul Kriteri	Araç/Standart
Penetrasyon Testi	Web Dashboard, API, Gateway, iletişim kanalları	Kritik ve Yüksek bulgu yok	OWASP Testing Guide, PTES
SAST	Tüm kaynak kod	Kritik bulgu yok, Yüksek bulgular azaltılmış	OWASP ASVS L2
DAST	Çalışan uygulama (staging ortamı)	OWASP Top 10 zafiyeti yok	OWASP ZAP / Burp Suite
SCA	Tüm 3. parti bileşenler	Bilinen Kritik/Yüksek CVE yok	OWASP Dependency-Check
Konfigürasyon Denetimi	Sunucu, veritabanı, ağ konfigürasyonu	CIS Benchmark uyumu	CIS Benchmarks
Şifreleme Denetimi	TLS, mTLS, veri şifreleme, anahtar yönetimi	TLS 1.3, güçlü cipher suite'ler	NIST SP 800-52
Erişim Kontrolü Testi	RBAC, oturum yönetimi, 2FA	Tüm roller doğru çalışıyor	OWASP ASVS
Olay Müdahale Tatbikatı	Simüle edilmiş güvenlik olayı	Prosedüre uygun müdahale	Olay müdahale planı

- Güvenlik test raporları Otokar'a teslim edilmelidir.
- Tüm test sonuçları bağımsız olarak doğrulanabilir olmalıdır.
- Kabul kriterleri karşılanmadan sistem üretime alınmamalıdır.

8. PERFORMANS VE ÖLÇEKLENEBİLİRLİK (NON-FUNCTIONAL REQUIREMENTS)

8.1. Eşzamanlılık (Concurrency)

Sistem, en az 15 aracın aynı anda veri gönderdiği, en az 15 kullanıcının (herhangi bir yetkide) aktif olduğu ve 3 kullanıcının aynı anda araç kameralarını izlediği yük altında, performans kaybı yaşamadan çalışabilmelidir.

8.2. Gecikme Sınırları (Latency Budget)

- Video gecikmesi (Glass-to-Glass): < 500 ms (4.5G ağında).
- Video dışı verilerin uzaktaki sunucuya iletim süresi < 200 ms (4.5G ağında).
- Uzak sunucudan araca komut iletim süresi: < 200 ms (4.5G ağında).
- Dashboard sayfa yüklenme süresi: < 2 saniye.

8.3. Veri İletim Frekansları

EK-3'te belirtilen frekanslarda araçtan server'a veri iletimi gerçekleştirilmelidir.

8.4. Operatör Tarafı Donanım Yedekliliği (Redundancy)

Operatör tarafındaki donanımsal arızalara karşı sistem sürekliliği sağlanmalıdır:

- Operatör kontrol merkezinde en az bir yedek terminal (standby workstation) bulunmalıdır.
- Yedek terminal, birincil terminalin arızalanması durumunda 2 dakika içinde devreye alınabilmelidir.
- Operatör oturumu, cihaz değişikliğinde kesintisiz olarak devam edebilmelidir (session portability).
- Operatör terminalinin arızalanması durumunda aktif araç izleme ve komut oturumları otomatik olarak diğer yetkili operatörlere veya yedek terminale atanmalıdır.
- Ağ bağlantısı kopan operatör terminali için araç tarafında otomatik Fail-Safe (güvenli duruş) modu devreye girmelidir.
- Birincil ve yedek terminaller arasında oturum durumu (session state) senkronize edilmelidir.

8.5. Güvenlik Performans Gereksinimleri

- Şifreleme/çözme işlemleri ek gecikmeyi 10ms'den fazla artırmamalıdır.
- Kimlik doğrulama işlemi (login) 2 saniyeden kısa sürede tamamlanmalıdır.
- Güvenlik logları, uygulama performansını %5'ten fazla düşürmemelidir.
- WAF/IDS kuralları, istek yanıt süresini 50ms'den fazla geciktirmemelidir.
- mTLS handshake süresi 500ms'den kısa olmalıdır.

9. BAKIM, DESTEK VE GARANTİ SÜRECİ

9.1. Garanti Süresi

Yüklenici, Kesin Kabul tarihinden itibaren 12 ay boyunca sistemde çıkacak yazılım hatalarını (Bug) ücretsiz gidermeyi taahhüt eder.

9.2. Operasyonel Servis Seviyesi Anlaşması (SLA)

Fonksiyonel hata ve arızalar için:

Seviye	Tanım	Müdahale Süresi	Çözüm Süresi
P1 - Kritik	Sistemin tamamen çalışmaması, araç-sunucu iletişim kesilmesi	< 30 dakika	< 4 saat
P2 - Yüksek	Kritik fonksiyonun çalışmaması (video, komut gönderme, MRM)	< 1 saat	< 8 saat
P3 - Orta	Önemli fonksiyonun çalışmaması (raporlama, filtreleme)	< 4 saat	< 1 iş günü
P4 - Düşük	Kozmetik hata, küçük fonksiyon bozukluğu	< 1 iş günü	< 5 iş günü

9.3. Siber Güvenlik Zafiyet SLA

Güvenlik zafiyetleri operasyonel hatalardan ayrı SLA ile yönetilir. Zafiyet sınıflandırma ve düzeltme süreleri için bkz. madde 6.5.1 (Zafiyet Sınıflandırma) ve madde 6.5.2 (Zafiyet Düzeltme SLA). Kritik ve Yüksek seviyeler için 7/24, Orta ve Düşük seviyeler için mesai saatleri içinde müdahale geçerlidir.

SLA kapsamında ek yükümlülükler:

- Kritik zafiyetlerde yüklenici 7/24 ulaşılabilir güvenlik müdahale ekibi sağlamalıdır.
- Aktif olarak istismar edilen (actively exploited) zafiyetlerde CVSS puanından bağımsız olarak Kritik SLA uygulanır.
- Zero-day zafiyetlerinde geçici çözüm (workaround/virtual patching) 4 saat içinde sağlanmalıdır.
- Her düzeltme sonrası, düzeltmenin etkinliğini doğrulayan re-test raporu sunulmalıdır.
- SLA metrikleri aylık olarak raporlanmalı ve performans değerlendirmesine dahil edilmelidir.

9.4. SLA İhlali Yaptırımları

- Kritik zafiyet SLA ihlali: Her 24 saat gecikme başına aylık bakım bedelinin %10'u cezai şart.
- Yüksek zafiyet SLA ihlali: Her 7 gün gecikme başına aylık bakım bedelinin %5'i cezai şart.

- Bir yılda 3'ten fazla Kritik SLA ihlali durumunda Otokar'ın sözleşmeyi fesih hakkı saklıdır.
- Yaptırımlar, garanti süresi boyunca ve sonrasındaki bakım sözleşmesi süresince geçerlidir.

9.5. Güvenlik Güncelleme Yükümlülüğü

- Yüklenici, garanti süresi boyunca ve bakım sözleşmesi süresince güvenlik güncellemesi sağlamakla yükümlüdür.
- Güvenlik güncellemeleri, fonksiyonel güncellemelerden bağımsız olarak yayınlanabilmelidir (hotfix mekanizması).
- Güvenlik güncellemesi, mevcut fonksiyonları bozmadığını doğrulayan regresyon testi ile birlikte sunulmalıdır.
- Üçüncü parti bileşen güvenlik güncellemeleri de bu SLA kapsamındadır.

9.6. Kaynak Kod ve Lisans Devri

Proje bitiminde geliştirilen tüm Kaynak Kodlar (Source Code), telif hakları ve 3. parti kütüphane lisansları Otokar'a devredilecektir. Vendor kilitlenmesi (Vendor Lock-in) olmamalıdır.

- Kaynak kod ile birlikte tüm güvenlik test raporları, TARA çıktıları ve zafiyet geçmişi devredilmelidir.
- Şifreleme anahtarları ve sertifikaların güvenli devir prosedürü tanımlanmalıdır.
- SBOM (Software Bill of Materials) güncel haliyle devredilmelidir.
- CI/CD pipeline konfigürasyonu ve güvenlik kapıları tanımları devredilmelidir.

10. UYUMLULUK VE REGÜLASYON GEREKSİNİMLERİ

10.1. ISO/SAE 21434 - Otomotiv Siber Güvenlik

- Yazılım geliştirme süreci, ISO/SAE 21434 (Road Vehicles - Cybersecurity Engineering) standardına uygun olmalıdır.
- TARA (Threat Analysis and Risk Assessment) yüklenici tarafından yazılım seviyesinde gerçekleştirilmelidir.
- Cybersecurity Interface Agreement (CIA) kapsamındaki tüm work product'lar zamanında teslim edilmelidir.

10.2. UNECE WP.29 R155/R156

- R155 - Cybersecurity Management System (CSMS): Yazılım, CSMS gereksinimlerini destekleyecek şekilde tasarlanmalıdır.
- R156 - Software Update Management System (SUMS): OTA güncelleme mekanizması R156 gereksinimlerini karşılamalıdır.
- Tip onayı için gerekli dokümantasyon yüklenici tarafından desteklenmelidir.

10.3. KVKK / GDPR Uyumu

- Sistemde işlenen kişisel veriler (operatör bilgileri, araç konum geçmişi, sesli iletişim kayıtları) KVKK kapsamında değerlendirilmelidir.
- Veri işleme envanteri hazırlanmalıdır.
- Kişisel veri saklama süreleri belirlenmelidir.
- Veri sahibi hakları (erişim, silme, taşıma) teknik olarak desteklenmelidir.
- Veri ihlali durumunda bildirim mekanizması tanımlanmalıdır.

10.4. Diğer Standartlar ve Referanslar

- OWASP Top 10 (2021): Web uygulama güvenliği referansı.
- OWASP ASVS v4: Application Security Verification Standard - doğrulama seviyesi L2.
- NIST Cybersecurity Framework: Risk yönetimi çerçevesi.
- CIS Benchmarks: Sunucu ve altyapı konfigürasyon güvenliği.
- CERT Secure Coding Standards: Güvenli kodlama referansı.

REFERANS DOKÜMANLAR

- EK-1: Desteklenen Uzaktan Komut Listesi (Excel)
- EK-2: Arayüz Tasarım Slaytları ve Sayfa Yerleşimleri (Görsel Referans)
- EK-3: Telemetri Veri Frekansları ve Büyüklükleri
- EK-4: Siber Güvenlik Sorumluluk Matrisi (CIA)